

MAINNET RELAYER SECURITY

UNIFYVAULT V2 — MAINNET RELAYER & PAYMASTER SECURITY ARCHITECTURE

****Scope**:** Security analysis, credential protection, and recommended cloud KMS/HSM signing architecture for production ERC-4337 Account Abstraction on Base Mainnet.

1. Security Invariants & Policy Boundaries

flowchart TD

```

    subgraph ClientLayer["Frontend Client (Browser / Safe App)"]
        Browser["User Browser / Injected Wallet / AA Client"]
    end

    subgraph APILayer["Next.js Server API Routes (Isolated)"]
        SponsorRoute["/api/smart-account/sponsor\n(Calldata & Policy Validation)"]
        BundlerRoute["/api/smart-account/bundler\n(UserOp Submitter / Forwarder)"]
    end

    subgraph HardwareSigner["Production Enterprise Signer"]
        KMS["Cloud KMS / HSM Signer\n(AWS KMS / GCP Cloud HSM / Turnkey)\nZero Plaintext Key Storage"]
    end

    subgraph BaseMainnet["Base Mainnet (Chain ID: 8453)"]
        BundlerPimlico["Production Bundler (Pimlico / Alchemy)"]
        EntryPoint["EntryPoint v0.7\n0x0000000071727De22E5E9d8BAf0edAc6f37da032"]
        Paymaster["UnifyVaultPaymaster\n(On-Chain Signature & Policy Validation)"]
    end

    Browser -->|Unsigned UserOp / Calldata| SponsorRoute
    SponsorRoute -->|Policy Validated Request| KMS
    KMS -->|ECDSA Paymaster Signature| SponsorRoute
    SponsorRoute -->|Signed PaymasterAndData| Browser
    Browser -->|Signed UserOp| BundlerRoute
    BundlerRoute -->|JSON-RPC eth_sendUserOperation| BundlerPimlico
    BundlerPimlico -->|handleOps()| EntryPoint
    EntryPoint -->|validatePaymasterUserOp()| Paymaster
  
```

Critical Security Boundaries

- **Client Isolation**:** Private keys NEVER reach the client bundle, browser runtime, or client-side telemetry.
- **Strict Calldata Policy**:** Every sponsorship request is inspected against an approved whitelist of contract targets (USDC, UnifyVaultController, UVBEToken, P2PEscrow) and whitelisted function selectors.
- **Zero Native Value Transfer**:** Sponsored operations are strictly forbidden from transferring native ETH (`value == 0`).
- **Time-Bounded Signatures**:** Paymaster signatures are valid for a maximum of 300 seconds (`validUntil = timestamp + 300`, `validAfter = 0`).
- **On-Chain Cost Limits**:** `UnifyVaultPaymaster` enforces `maxCostPerUserOp` (default \$0.01\text{ ETH}\$) and `maxFeePerGasCap` to protect gas reserves against runaway spikes.
- **Rate Limiting**:** Cooldown windows are enforced per user operation sender.

2. Production Signer Security: Plaintext vs. Cloud KMS / HSM

- **Security Dimension**: Plaintext ``env`` Key (Testnet Only) | Cloud KMS / HSM (Production Mainnet Requirement)
- **Storage Location**: Disk / Server process memory | Hardware Security Module (FIPS 140-2 Level 3)
- **Exfiltration Risk**: High (Server compromise exposes key) | Near Zero (Private key cannot be exported)
- **Access Control**: File permissions only | Granular IAM, IP allowlisting, and CloudTrail audit logging
- **Key Rotation**: Manual and disruptive | Zero-downtime key versioning
- **Usage**: **TESTNET ONLY** | **MANDATORY FOR MAINNET LAUNCH**

[!CAUTION]

DO NOT USE A PLAINTEXT PRIVATE KEY ON THE PRODUCTION APPLICATION SERVER.

For Base Mainnet launch, all Paymaster verification signatures and relay UserOp broadcasts must use a Cloud KMS (e.g. AWS KMS ``ECC_SECG_P256K1`` or Google Cloud KMS) or enterprise signing sidecar (Turnkey / Fireblocks).

3. Gas Treasury Reserve & Balance Monitoring Requirements

1. **Paymaster EntryPoint Deposit Alerting**:
 - Critical Alert: EntryPoint deposit $\leq 0.1 \text{ ETH}$.
 - Warning Alert: EntryPoint deposit $\leq 0.5 \text{ ETH}$.
1. **Gas Treasury Balance Monitoring**:
 - Automated heartbeat monitoring every 5 minutes via cron/Prometheus.
 - Refill alerts triggered when Gas Treasury reserve $\leq 1.0 \text{ ETH}$.
1. **Daily Limit Safeguard**:
 - ``GasTreasury.dailyRefillLimit`` (e.g. $\$2.0 \text{ ETH}$) prevents unlimited fund draining if an operator key is compromised.
 - ``GasTreasury.maxRefillPerTx`` (e.g. $\$0.5 \text{ ETH}$) bounds single transaction refill volume.